ORDEN DE TRABAJO TÉCNICA — PLAN DE ACCIÓN

Estabilización de Bandeja Omnicanal, Blindaje de Webhook, Seguridad Multi-Sede y Estandarización WABA v23.0

OT-STARFI-2026-11-FIX

Emisión: 12/11/2026

DIRIGIDO A	RAMA DE TRABAJO	PRIORIDAD GLOBAL	TOTAL ÍTEMS
Operador / Desarrollo & QA	development (HEAD 50e4efe)	CRÍTICA / EJECUCIÓN INMEDIATA	15 Tareas en 4 Fases

Objetivo Ejecutivo: Corregir de forma ordenada y verificable los hallazgos detectados tras la auditoría de los commits recientes (`27cb2f7` , `094e47b` , `50e4efe`) y de la operación general de **STARFI CRM**, garantizando notificaciones en tiempo real exactas por rol/sede, clasificación limpia entre Ventas y Campañas, idempotencia y alta velocidad en el Webhook de Meta, cierre de brechas de seguridad y unificación a Graph API `v23.0` .

FASE 1 • CRÍTICA
Bandeja & Campañas
BAN-01 a BAN-04 • SSE por rol/sede, filtro Ventas y locks

FASE 2 • ALTA
Motor Webhook
WHK-01 a WHK-03 • Idempotencia, conteo rápido y HTTP 200

FASE 3 • SEGURIDAD
Accesos & Secretos
SEC-01 a SEC-04 • Media, permisos por sede, .env y limpieza

FASE 4 • ESTANDARIZACIÓN
Graph v23.0 & KPIs
STD-01 a STD-04 • API v23.0, vCards sede, CAC real y legado

FASE 1 — ESTABILIZACIÓN INMEDIATA EN BANDEJA OMNICANAL Y CAMPAÑAS

Prioridad 1 • Producción en Vivo

CÓD.	REQUERIMIENTO & ARCHIVOS	PROBLEMA DETECTADO Y ESPECIFICACIÓN DE CORRECCIÓN	CRITERIO DE ACEPTACIÓN (DOD)
BAN-01	**Corregir visibilidad SSE por Rol/Sede y estados en vivo** `modules/bandeja/sse_updates.php (L13-45)`	**Problema:** El filtro `c.id_agente = $agente_id OR c.estado = 'ESPERA_ASIGNACION' OR $agente_id = 1` deja sin alertas SSE en tiempo real a `ADMINISTRADOR` , `GERENTE` y `MASTER` (`id != 1`) en chats activos (`ATENDIENDO`), y dispara recargas cruzadas entre sedes distintas en `ESPERA_ASIGNACION` . Además, evaluar solo `m.id > $last_msg_id` ignora cambios de `estado_envio` (`ENTREGADO` , `LEIDO` , `FALLIDO`). **Solución:** Leer rol e `id_sede` con `getAgenteInfo()` antes de `session_write_close()` ; unir con `lineas_whatsapp` para acotar `l.id_sede = $user_sede` en roles no-Master; permitir todos los chats de su sede a Admin/Gerente y restringir a `id_agente` /espera solo a `OPERADOR` ; incorporar detección ligera de cambios de `estado_envio` recientes.	• Admin/Gerente recibe alerta SSE en chats asignados a vendedores de su sede. • Operador de Sede A no recibe eventos de Sede B. • Doble check azul y errores Meta actualizan sin `F5` .
BAN-02	**Eliminar falsos positivos en pestaña y etiqueta Ventas** `modules/bandeja/back_bandeja.php (L131-138, L288-296)`	**Problema:** `flag_venta` marca como venta todo `origen = 'API_TRANSACCIONAL'` con `contenido NOT LIKE '%starfi_difusion_directa%'` . Las campañas con otras plantillas aprobadas guardan 📢 `[DIFUSIÓN: plantilla] | Texto: ...` y aparecen por error como **Venta**. **Solución:** Añadir `AND contenido NOT LIKE '%[DIFUSIÓN:%' AND contenido NOT LIKE '%| Texto:%'` tanto en el `WHERE` de `$filter === 'ventas'` como en el `CASE` de `flag_venta` en Fase 2.	• Ninguna campaña de difusión (cualquier plantilla) enciende `es_venta = 1` ni entra en la pestaña Ventas.

CÓD.	REQUERIMIENTO & ARCHIVOS	PROBLEMA DETECTADO Y ESPECIFICACIÓN DE CORRECCIÓN	CRITERIO DE ACEPTACIÓN (DOD)
BAN-03	**Desacoplar UPDATE de sincronización en load_chats** `modules/bandeja/back_bandeja.php (L8-11, L200-218)`	**Problema:** `load_chats` ejecuta un `UPDATE conversaciones c JOIN (...)` durante lecturas concurrentes y vuelve a invocar `getAgenteInfo()` 6 veces tras `session_write_close()`. **Solución:** Actualizar `conversaciones.ultimo_msg_id` directamente al insertar en `mensajes_y_eventos` (vía `TRIGGER AFTER INSERT` en MySQL con `GREATEST(ultimo_msg_id, NEW.id)` o en cada `INSERT`) dejando `load_chats` 100% de lectura, y reutilizar `$agente_info_global` en todo el archivo.	• `load_chats` no ejecuta escrituras `UPDATE` y responde en `< 80 ms` sin contención de locks.
BAN-04	**Conservar parseo JSON defensivo en Campañas** `modules/campanas/funciones_campanas.js (L244-258)`	**Problema:** Evitar revertir el bloque defensivo `resp.text()` + `JSON.parse()` en `recargarEcosistema()` a `resp.json()` directo. **Solución:** Mantener el `try/catch` sobre `resp.text()` para capturar respuestas HTML de error o timeouts `524` mostrando notificación controlada sin romper la vista.	• Árbol Git limpio y manejo controlado ante errores HTTP no-JSON.

FASE 2 — IDEMPOTENCIA, RENDIMIENTO Y RESPUESTA RÁPIDA EN WEBHOOK

Prioridad 2 • Escalabilidad WABA

CÓD.	REQUERIMIENTO & ARCHIVOS	PROBLEMA DETECTADO Y ESPECIFICACIÓN DE CORRECCIÓN	CRITERIO DE ACEPTACIÓN (DOD)
WHK-01	**Idempotencia estricta por id_mensaje_meta entrante** `webhook.php (L233-291)`	**Problema:** Al recibir un mensaje del cliente, `webhook.php` no verifica si el `wamid` (`id_mensaje_meta`) ya fue procesado. Si Meta reintenta la entrega por latencia, duplica el mensaje y dispara doble respuesta de la IA. **Solución:** Consultar por el índice `idx_meta_wamid` antes de `save_mensaje()`; si el `id_mensaje_meta` ya existe en `mensajes_y_eventos`, responder `HTTP 200` y terminar inmediatamente.	• Enviar 2 veces el mismo payload entrante registra 1 sola fila y genera 1 sola respuesta del bot.
WHK-02	**Optimizar recálculo de embudo en estados Meta** `webhook.php (L166-220)`	**Problema:** Cada evento `sent/delivered/read/failed` ejecuta `SHOW TABLES LIKE` + 7 subconsultas `SELECT COUNT(*)` sobre `campanas_difusion_destinatarios`, sobrecargando MySQL en campañas grandes. **Solución:** Eliminar `SHOW TABLES LIKE` repetitivo y reemplazar las 7 subconsultas por un solo `UPDATE campanas_difusion c INNER JOIN (SELECT SUM(...) ... GROUP BY id_campana)` indexado.	• Actualización de contadores de campaña en 1 sola pasada agregada sin subconsultas correlacionadas.
WHK-03	**Responder HTTP 200 a Meta antes de IA / usleep** `webhook.php (L482-604, L729-772)`	**Problema:** El webhook retiene abierta la petición de Meta durante la llamada a Gemini (hasta 10s) y el bucle de contactos con `usleep(500000)`. **Solución:** Tras guardar el mensaje entrante, cerrar la entrega HTTP `200 OK` hacia Meta (`fastcgi_finish_request()` o cabeceras `Connection: close` + `flush()` + `ignore_user_abort(true)`) antes de ejecutar la IA y el envío de contactos.	• Meta recibe `HTTP 200` en `< 300 ms` mientras la IA responde en segundo plano.

FASE 3 — BLINDAJE DE SEGURIDAD, PERMISOS MULTI-SEDE E HIGIENE

Prioridad 3 • Seguridad Productiva

CÓD.	REQUERIMIENTO & ARCHIVOS	PROBLEMA DETECTADO Y ESPECIFICACIÓN DE CORRECCIÓN	CRITERIO DE ACEPTACIÓN (DOD)
SEC-01	**Autenticación y SQL preparado en get_media.php** `get_media.php (L70-149)`	**Problema:** `get_media.php` no exige sesión activa (`requireAuth()`) e interpola `$_GET['id']` directamente en `LIKE '%$media_id%'` (riesgo de SQL Injection). **Solución:** Incluir `core/auth.php` + `requireAuth()` + `session_write_close()` , validar acceso del usuario a la sede del `chat_id` y usar consultas preparadas (`prepare/bind_param`).	• Acceso sin sesión devuelve `401/403` ; bloqueo entre sedes y 0 concatenación SQL directa.

SEC-02	**Validar propiedad de Sede en mutaciones Bots y Bandeja**
	`modules/gestor_bots/back_gestor_bots.php (L77-166)`
	`modules/bandeja/back_bandeja.php (L670-890)`
		Problema: `delete_rule` , `update_network` y `delete_contacto` operan solo por `id` sin filtrar `id_sede` . En Bandeja, `retry_message` , `close_chat` y `mark_as_read` no validan pertenencia del chat a la sede/operador.
		Solución: Restringir con `AND id_sede = ?` toda escritura/borrado para usuarios no-Master y verificar autorización sobre `conversacion_id` en Bandeja.
			• Un usuario no-Master no puede alterar ni borrar reglas, contactos o chats de otra sede vía POST.

SEC-03	**Externalizar secretos y tokens al archivo .env**
	`config/database.php (L14-47)`
	`webhook.php (L17-19)`
		Problema: `META_GLOBAL_TOKEN` , IPs de servidores y contraseñas de BD están fijas en el código PHP.
		Solución: Consumir credenciales y tokens desde `.env` , crear plantilla `.env.example` sin secretos reales y habilitar validación SSL en cURL (`CURLOPT_SSL_VERIFYPEER = true`).
			• Cero tokens Meta o claves MySQL quemadas literalmente en archivos PHP versionados.

SEC-04	**Limpieza de scripts de prueba y bloqueo .htaccess**
	`Raíz starfi_crm/ & .htaccess`
	`api_notificaciones.php (L548)`
		Problema: Archivos de volcado/prueba (`export_databases.php` , `print_all_rows.php` , `scratch_*.php` , `test*.php` , `test_meta_payload.log`) y `/logs/webhook_*.log` están en directorios públicos.
		Solución: Eliminar scripts temporales y el log de debug en `api_notificaciones.php` ; configurar `.htaccess` denegando acceso web a `/logs/` , `/config/` , `/core/` , `.env` , `.sql` y `.log` .
			• Peticiones HTTP a `/logs/` o `/.env` devuelven `403 Forbidden` ; raíz limpia.

FASE 4 — ESTANDARIZACIÓN META v23.0, PRECISIÓN DE KPIS Y DEUDA TÉCNICA

Prioridad 4 • Calidad y Mantenibilidad

CÓD.	REQUERIMIENTO & ARCHIVOS	PROBLEMA DETECTADO Y ESPECIFICACIÓN DE CORRECCIÓN	CRITERIO DE ACEPTACIÓN (DOD)
STD-01	**Unificar todas las llamadas a Meta Graph API v23.0** `back_bandeja.php, get_media.php, webhook.php`	**Problema:** Persisten endpoints apuntando a `graph.facebook.com/v19.0` mientras Campañas y Facturación usan `v23.0` . **Solución:** Declarar constante central `META_API_VERSION = 'v23.0'` y actualizar todas las llamadas cURL restantes.	• 0 referencias a `v19.0` en el código; envíos de texto, medios y plantillas en `v23.0` .
STD-02	**Nombre dinámico de Sede en tarjetas vCard del Bot** `webhook.php (L709-750)`	**Problema:** `enviar_contactos_asesores()` envía fijo el apellido `'SuperFormica'` para todas las sedes. **Solución:** Leer `nombre_sede` desde la tabla `sedes` según `$id_sede` y asignarlo dinámicamente al contacto vCard.	• Cada sede envía sus tarjetas de contacto con su propio nombre comercial.

CÓD.	REQUERIMIENTO & ARCHIVOS	PROBLEMA DETECTADO Y ESPECIFICACIÓN DE CORRECCIÓN	CRITERIO DE ACEPTACIÓN (DOD)
STD-03	**Reemplazar datos simulados en Dashboard General** `modules/dashboard/back_dashboard.php (L53-83)`	**Problema:** Asigna `15 min` ficticios cuando no hay ventas cerradas y calcula el `CAC` con `$0.10` fijo por chat. **Solución:** Mostrar `0 min` si no existen cierres y calcular el `CAC` usando el gasto real de campañas y mensajes facturables del periodo.	• KPIs de Ciclo de Ventas y CAC muestran valores 100% reales de base de datos.
STD-04	**Deprecar rutinas antiguas de difusión en Directorio** `modules/directorio/back_directorio.php (L10-68, L210-250)`	**Problema:** Mantiene funciones legadas (`ensureBroadcastTables` , `send_broadcast_item`) con estructura antigua de campañas. **Solución:** Retirar los `case` obsoletos de difusión en Directorio para centralizar todo en `modules/campanas/` .	• Un único motor y esquema de campañas activo en `modules/campanas/back_campanas.php` .

CHECKLIST OBLIGATORIO DE ENTREGA Y CONTROL DE CALIDAD (QA)

- [ ] **Flujo Git:** Trabajar en `development` con commits atómicos por fase antes de solicitar merge a `main` .
- [ ] **Prueba SSE Multi-Rol:** Validar con sesión simultánea Admin + Operador que los mensajes entrantes actualizan en `< 3s` solo en su sede.
- [ ] **Prueba Idempotencia Webhook:** Reenviar mismo `id_mensaje_meta` 2 veces y confirmar 0 mensajes duplicados.
- [ ] **Sintaxis Limpia:** Ejecutar `php -l` en cada archivo tocado garantizando 0 errores o warnings fatales.
- [ ] **Prueba Ventas vs Campañas:** Verificar que ninguna difusión con plantilla personalizada aparezca marcada como Venta.
- [ ] **Prueba Seguridad Media:** Abrir `get_media.php` sin sesión (incógnito) y confirmar bloqueo inmediato de acceso.